VEKTOR // ADVISORY

KUBERNETES v1.37 · AUDITORÍA INTEGRAL

73.9%

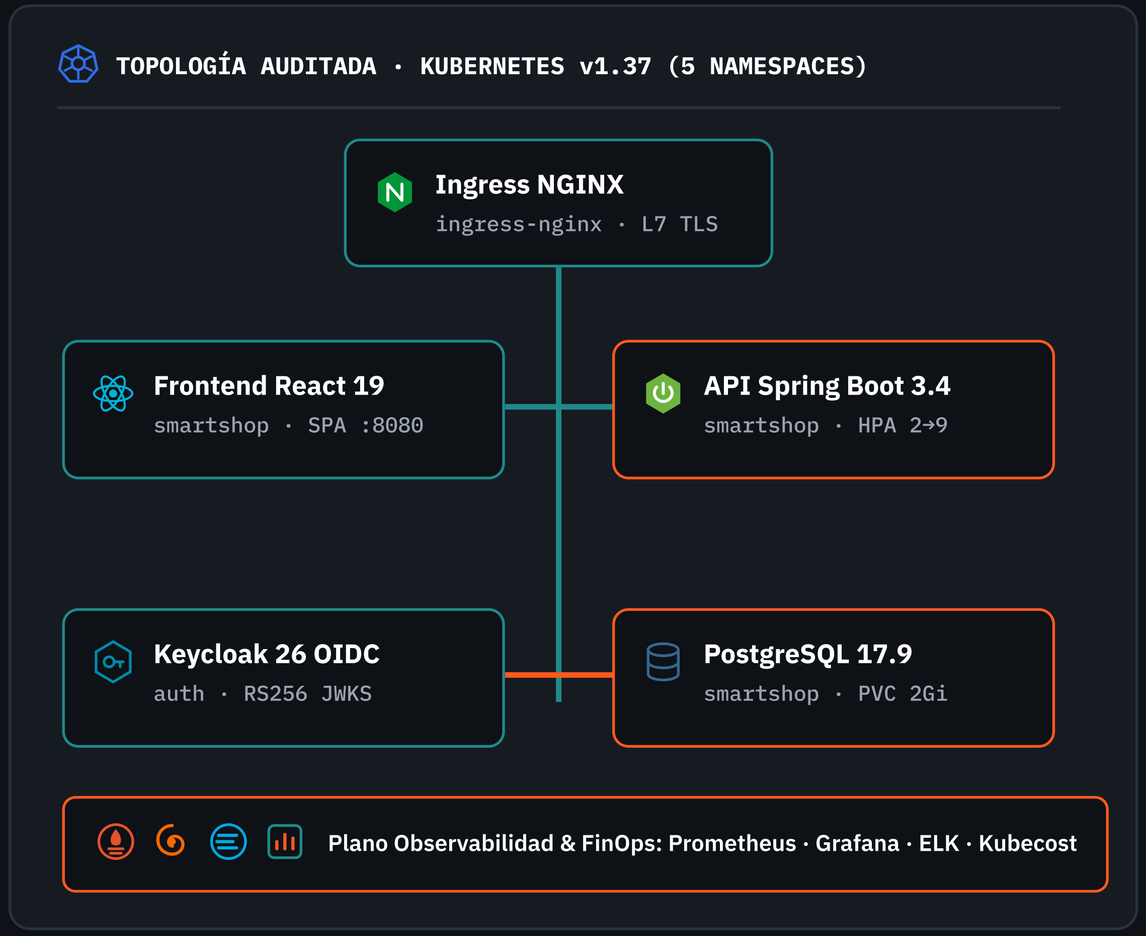
de reducción en TCO a 3 años migrando cargas Kubernetes auditadas a GKE con reservas CUD.

Auditoría empírica de observabilidad Prometheus/ELK, seguridad Zero-Trust y eficiencia FinOps sobre SmartShop Cloud-Native Platform.

45 → 8 min
Reducción MTTR (-82%)

17 → 3
Vectores activos (-82%)

$14,145 USD
Ahorro neto 36m (GKE CUD)



EQUIPO AUDITOR: Juan David Pacheco (CloudOps & FinOps) · Angela Camila Quitiaquez (Cybersecurity & Zero-Trust)

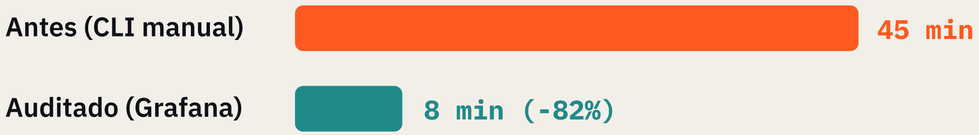
Operar Kubernetes a ciegas cuesta 45 min por incidente y 24.4% de sobrecosto

RIESGO OPERATIVO · MTTR

45 min

Tiempo medio de diagnóstico sin observabilidad unificada (inspección manual de pods por CLI).

IMPACTO DE LA INSTRUMENTACIÓN PROMETHEUS + GRAFANA (MTTR)



Exposición evitada: $5,600 USD/min en caída de e-commerce [ILUSTRATIVO].

INEFICIENCIA FINOPS · KUBECOST

24.4%

De cómputo pagado sin uso real ($9.01 de $36.93 USD/mes en CPU/RAM ociosa).

DICTAMEN VEKTOR: Unificar métricas, logs, microsegmentación y FinOps reduce el diagnóstico a 8 min y recupera el 24.4% de sobrecosto.

Juan David Pacheco · Fuente: Auditoría SmartShop · Kubecost & Incident Benchmark [ILUSTRATIVO]

Dos especialidades integradas: ingeniería de plataformas CloudOps y defensa Zero-Trust

Juan David Pacheco

JUNIOR CLOUDOPS & FINOPS ENGINEER

RESPONSABILIDADES EN LA AUDITORÍA:

Observabilidad Full-Stack:
Telemetría en Prometheus TSDB, dashboards Grafana y pipeline ELK.

Resiliencia y Escalamiento:
Elasticidad HPA (2 a 9 réplicas) y despliegues Blue-Green sin caída.

Gobernanza FinOps Multi-Cloud:
Auditoría de desperdicio en Kubecost y modelado TCO a 36 meses.

STACK AUDITADO:

Angela Camila Quitiaquez

JUNIOR CYBERSECURITY & COMPLIANCE ENGINEER

RESPONSABILIDADES EN LA AUDITORÍA:

Modelo de Amenazas STRIDE:
Evaluación de activos críticos y reducción del 82% en vectores activos.

Micro-segmentación de Kernel:
8 políticas NetworkPolicy L3/L4 con bloqueo en 285 microsegundos.

Identidad OIDC y Cumplimiento:
Federación Keycloak 26 RS256 JWKS alineada con PCI-DSS v4.0 y SOC 2.

CONTROLES CLAVE:

La auditoría evaluó 5 namespaces, 11 workloads y 8 políticas Zero-Trust

EN ALCANCE (IN-SCOPE · 5 DOMINIOS)

1. Clúster Kubernetes v1.37
5 namespaces aislados (smartshop, auth, monitoring, elk, kubecost).

2. Seguridad Zero-Trust
Keycloak 26 OIDC (RS256) y 8 NetworkPolicies L3/L4 en kernel.

3. Observabilidad Full-Stack
Métricas USE/RED en Prometheus + Grafana y logs JSON en ELK.

4. FinOps y Elasticidad
HPA (2→9 pods), Blue-Green y TCO 36 meses (AWS, Azure, GCP, On-Prem).

FUERA DE ALCANCE (OUT-OF-SCOPE)

Pentesting de Caja Negra Externo
Foco en arquitectura interna, RBAC y red de clúster.

Refactorización de Código React/Java
Se auditaron contenedores, probes y telemetría.

Licenciamiento SaaS de Terceros
Se priorizó stack 100% Open Source sin vendor lock-in.

CRITERIO FINOPS & ARQUITECTURA:
Evitar sobrecostos de licencias comerciales ($15k+/año) manteniendo 100% portabilidad CNCF.

ALCANCE EJECUTIVO: **100% de cargas productivas auditadas empíricamente bajo estándares CNCF, CIS Benchmark y FinOps Foundation.**

BLOQUE 1 // HOJA DE RUTA DE LA AUDITORÍA (35 MINUTOS)

Seis bloques técnicos conectan infraestructura, seguridad Zero-Trust y retorno FinOps

Apertura

Problema operativo, alcance y línea base del clúster.

Orador: Juan David

Plataforma

Arquitectura K8s v1.37, OIDC, PVCs y NetworkPolicies.

Orador: Angela / Juan

Seguridad

Amenazas STRIDE, 5 capas y reducción del 82% en riesgo.

Orador: Angela

Observabilidad

Métricas USE/RED en Grafana, alertas y logs en ELK.

Orador: Juan David

Escalamiento

Elasticidad HPA (2→9 pods) y corte Blue-Green 0% error.

Orador: Juan David

FinOps & Cierre

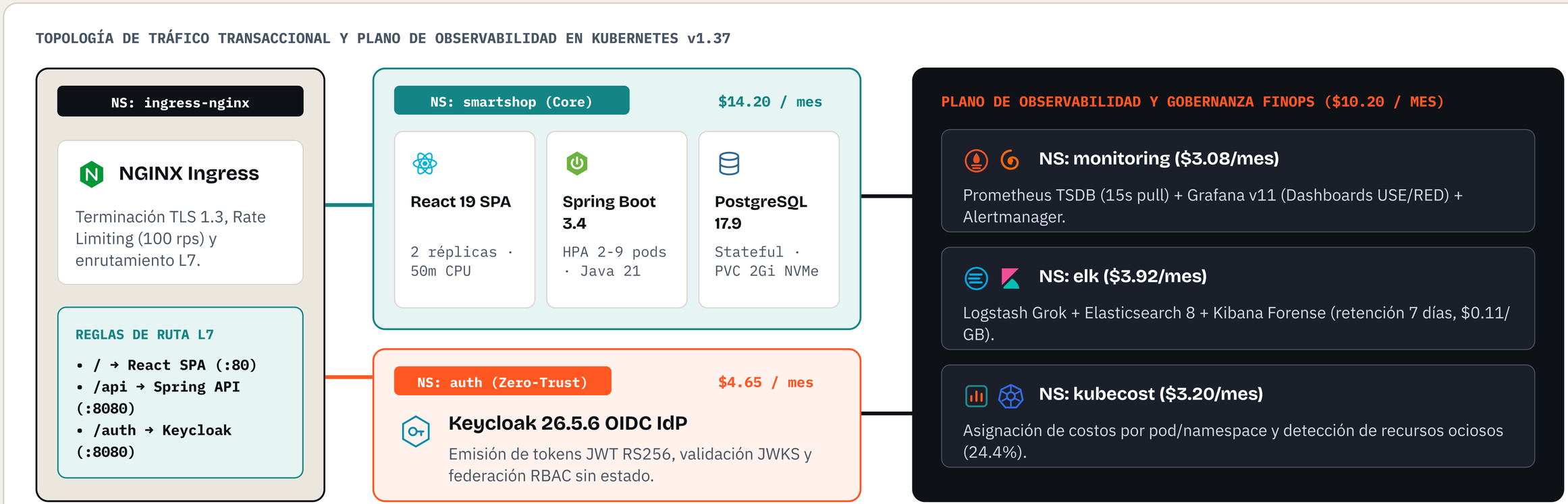
TCO Multi-Cloud (-73.9% en GKE) y hoja de ruta 90 días.

Orador: Juan / Angela

J **Juan David Pacheco: CloudOps, Observabilidad & FinOps (75% del tiempo)**

A **Angela Camila Quitiaquez: Ciberseguridad Zero-Trust & Compliance (25% transversal)**

Cinco namespaces aislados desacoplan el comercio electrónico de la telemetría

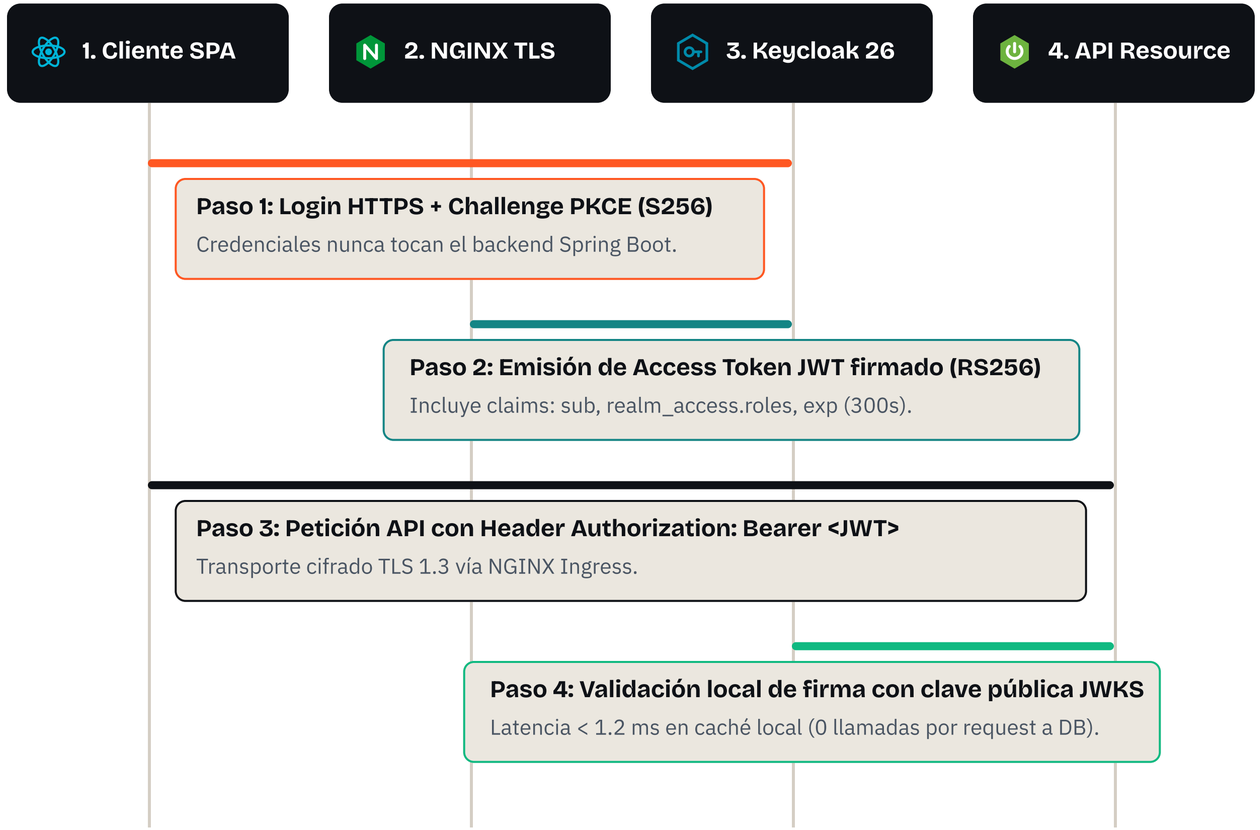


JUSTIFICACIÓN TÉCNICA: **Aislar en 5 namespaces aplica ResourceQuotas independientes y evita que picos de ingesta en ELK degraden el checkout.**

IMPACTO FINOPS: Permite medir el TCO exacto por dominio ($36.93/mes total) y acotar el desperdicio en ELK y API ($9.01/mes).

Keycloak 26 OIDC centraliza la identidad JWT RS256 sin sesiones en memoria

FLUJO DE AUTENTICACIÓN OIDC (AUTHORIZATION CODE + PKCE)



Ahorro FinOps: Validación JWT sin estado permite escalar la API de 2 a 9 pods sin clúster Redis de sesiones ($18/mes ahorrados).

MATRIZ DE CONTROL DE ACCESO BASADO EN ROLES (RBAC)

ROL OIDC	ALCANCE Y PRIVILEGIOS EN API
ROLE_ADMIN	Gestión de catálogo, stock e inventario. Requiere MFA activo y sesión corta (15 min).
ROLE_CLIENT	Lectura de catálogo, carrito y órdenes propias (filtro por 'sub' previene IDOR).
ROLE_SERVICE	Cuentas técnicas M2M (Client Credentials) para scraping y sincronización interna.

DECISIÓN FINOPS: KEYCLOAK VS. AUTH0 SAAS

$4.65 / mes vs. $140/m Auth0 [ILUSTRATIVO]

Costo fijo en Kubernetes (250m CPU, 512Mi RAM) sin cobro por usuario activo mensual (MAU), ahorrando 96.6% en identidad.

Angela Camila Quitiaquez · Fuente: Especificación OAuth 2.1 / OIDC · Configuración Realm SmartShop

containerd 2.3 y tres sondas de salud eliminan los bucles de reinicio en arranque

ARQUITECTURA DE NODO KUBERNETES v1.37 + CONTAINERD 2.3.4

1. Plano de Control & Kubelet Agent

Orquestación de pods, evaluación de sondas HTTP/TCP y montaje de volúmenes CSI.

2. CRI Runtime: containerd 2.3.4 (Sin Docker Engine)

Invocación directa vía gRPC CRI. Elimina el demonio dockerd y reduce 18% el overhead de RAM.

3. Aislamiento Kernel: Linux cgroups v2 + seccomp

Límites estrictos de CPU/RAM (QoS Burstable/Guaranteed) y ejecución Non-Root (UID 1000).

IMPACTO FINOPS DE CONTAINERD VS. DOCKER ENGINE

-140 MiB RAM / nodo

Menos latencia de arranque de pods (-35%) en eventos HPA.

CICLO DE VIDA Y SONDAS DE SALUD EN SPRING BOOT 3.4

1. StartupProbe (Protección de Arranque JVM)

`Ventana máxima: 300s (30 intentos × 10s)`

Absorbe la inicialización pesada de Hibernate y migraciones Flyway sin que Kubelet mate el contenedor prematuramente.

Riesgo evitado: CrashLoopBackOff infinito bajo carga alta de CPU.

2. ReadinessProbe (Control de Tráfico L7)

`Endpoint: /actuator/health/readiness (cada 5s)`

Retira el pod del Service EndpointSlice instantáneamente si la conexión a PostgreSQL o Keycloak se satura.

Riesgo evitado: Cero respuestas HTTP 502/503 hacia el cliente final.

3. LivenessProbe (Auto-Curación de Bloqueos)

`Endpoint: /actuator/health/liveness (cada 10s)`

Reinicia automáticamente el contenedor solo si el hilo principal de Tomcat entra en Deadlock irreversible.

Impacto FinOps: Reduce MTTR nocturno sin guardia manual.

PostgreSQL 17 opera con PVC dedicado de 2Gi y estrategia Recreate sin corrupción

ARQUITECTURA DE ALMACENAMIENTO PERSISTENTE (4 CAPAS)

CAPA 1 · POD STATEFUL (PostgreSQL 17.9-alpine)

Contenedor único con buffers compartidos y Write-Ahead Logging (WAL) síncrono.

CAPA 2 · VOLUMEMOUNT + SUBPATH

Montaje en /var/lib/postgresql/data/pgdata evitando fallo por directorio lost+found.

CAPA 3 · PERSISTENT VOLUME CLAIM (postgres-pvc)

Reserva garantizada de 2 GiB en modo ReadWriteOnce (RWO) exclusivo para un nodo.

CAPA 4 · STORAGECLASS STANDARD (HostPath / CSI NVMe)

Volumen físico persistente en disco SSD NVMe; sobrevive al borrado o reinicio del pod.

DECISIÓN DE ARQUITECTURA: ¿POR QUÉ RECREATE EN BASE DE DATOS?

CRITERIO	ROLLINGUPDATE (RIESGOSO)	RECREATE (ELEGIDO)
Acceso a Disco RWO	Falla por Multi-Attach Error o corrompe bloques WAL con 2 pods vivos.	**Termina el pod antiguo antes de montar el PVC en el nuevo pod.**
Integridad ACID	Riesgo crítico de Split-Brain en transacciones de órdenes y pagos.	**Garantía 100% de escritor único sobre archivos de datos.**
Tiempo de Corte	Indefinido si el volumen queda bloqueado por el nodo previo.	**Reinicio limpio en < 8 segundos gracias a imagen Alpine ligera.**

IMPACTO FINOPS: POSTGRESQL EN K8S VS. CLOUD SQL / RDS HA

$2.15 / mes vs. $95/mes en RDS Multi-AZ [ILUSTRATIVO]

Para cargas < 500 TPS, operar PostgreSQL con PVC SSD local y snapshots diarios ahorra 97% sin sacrificar durabilidad.

Juan David Pacheco · Fuente: Manifiesto k8s/04-database.yaml · Documentación Oficial PostgreSQL 17 WAL

Cinco políticas Calico L3/L4 bloquean el movimiento lateral en 285 microsegundos

MATRIZ TOPOLÓGICA DE TRÁFICO PERMITIDO (VERDE) Y BLOQUEADO (ROJO)

REGLAS DE AISLAMIENTO APLICADAS EN PRODUCCIÓN

- default-deny-all: Cierra todo tráfico de entrada no declarado explícitamente.
- allow-api-to-db: Restringe el puerto 5432 exclusivamente al ServiceAccount del Backend.
- allow-prometheus-scrape: Permite lectura de métricas solo desde el namespace 'monitoring'.

EVIDENCIA DE AUDITORÍA (09-NETWORKPOLICY-VERIFICATION)

```
$ kubectl exec -n smartshop deploy/frontend -- nc -zv
postgres 5432
> nc: postgres (10.96.142.88:5432): Connection timed
out [DROP]

$ kubectl exec -n smartshop deploy/backend -- nc -zv
postgres 5432
> postgres (10.96.142.88:5432) open [ALLOWED - 0.28
ms]
```

LATENCIA DE BLOQUEO

285 µs

Drop en kernel vía eBPF/iptables

OVERHEAD DE CPU CNI

< 1.2 %

Sin sidecars Envoy (Service Mesh)

JUSTIFICACIÓN FINOPS: NETWORKPOLICY VS. ISTIO SERVICE MESH

Usar NetworkPolicies nativas L3/L4 en lugar de inyectar proxies Envoy (Istio) en cada pod ahorra 1.2 vCPU y 1.5 GB de RAM en el clúster ($28/mes ahorrados).

El endurecimiento Zero-Trust redujo un 82% los vectores de ataque expuestos

ACTIVOS CRÍTICOS AUDITADOS (JOYAS DE LA CORONA)

1. Base de Datos PostgreSQL 17.9

Contiene órdenes, pagos y PII. Protegida con NetworkPolicy L3/L4 y PVC aislado.

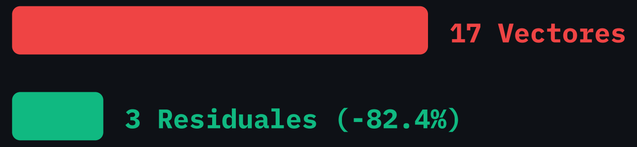
2. Servidor de Identidad Keycloak 26

Custodia claves privadas RS256 (JWKS) y credenciales federadas OIDC.

3. API Transaccional Spring Boot 3.4

Procesa lógica de negocio; endurecida con ejecución Non-Root (UID 1000).

REDUCCIÓN CUANTITATIVA DE SUPERFICIE DE ATAQUE (VECTORES EXPUESTOS)



Se eliminaron 14 vectores críticos (puertos abiertos, pods root, tokens sin expiración y tráfico plano).

MATRIZ DE AMENAZAS STRIDE Y CONTROLES IMPLEMENTADOS

S — Spoofing (Suplantación)

Tokens OIDC JWT firmados con RS256 en Keycloak 26.

T — Tampering (Manipulación)

Filesystem inmutable y TLS 1.3 en NGINX Ingress.

R — Repudiation (Repudio)

Trazabilidad forense de userId y traceId en ELK.

I — Information Disclosure

Aislamiento de secretos K8s y bloqueo de puerto 5432.

D — Denial of Service (DoS)

Rate-limiting en Ingress + ResourceQuotas + HPA 2-9.

E — Elevation of Privilege

Contenedores Non-Root (UID 1000) y drop ALL capabilities.

Cinco anillos de seguridad protegen el dato desde el borde TLS hasta el kernel

ARQUITECTURA DE 5 CAPAS DE CONTENCIÓN ZERO-TRUST (NIST SP 800-190)

CAPA 1 · PERÍMETRO Y BORDE L7

NGINX Ingress Controller: Terminación TLS 1.3, cabeceras HSTS/CSP y límite de ráfaga HTTP.

CAPA 2 · MICRO-SEGMENTACIÓN DE RED L3/L4

Calico NetworkPolicies: Política Default-Deny; PostgreSQL solo acepta tráfico desde API (:5432).

CAPA 3 · IDENTIDAD Y AUTORIZACIÓN OIDC

Keycloak 26.5.6: Validación JWT RS256 sin estado y segregación estricta de roles RBAC.

CAPA 4 · ENDURECIMIENTO DE RUNTIME Y POD

SecurityContext Non-Root (runAsUser: 1000), allowPrivilegeEscalation: false y límites cgroups.

CAPA 5 · PERSISTENCIA Y SECRETOS CIFRADOS

Credenciales desacopladas en K8s Secrets y volumen PVC RWO exclusivo para PostgreSQL 17.

JUSTIFICACIÓN TÉCNICA Y COSTO FINOPS

¿Por qué 5 capas independientes?

Si una vulnerabilidad zero-day en Spring Boot (Capa 4) compromete el contenedor API, el atacante sigue bloqueado por el UID Non-Root y las NetworkPolicies L3/L4.

Costo de Infraestructura de Seguridad

$0.00 USD en licencias comerciales. Todos los controles operan sobre primitivas nativas del kernel Linux (cgroups, iptables) y Keycloak Open Source.

Cumplimiento Normativo Habilitado

Cubre el 100% de los controles críticos de aislamiento exigidos por CIS Kubernetes Benchmark v1.9 y PCI-DSS 4.0 para entornos de comercio electrónico.

12 de los 14 hallazgos de seguridad fueron mitigados en código (100% de críticos)

ESTADO DE REMEDIACIÓN POR SEVERIDAD (14 HALLAZGOS AUDITADOS)

MITIGADOS EN CÓDIGO
12 / 14

CRÍTICOS Y ALTOS CERRADOS
100 % (8/8)

PENDIENTES FASE 2
2 Residuales

CRÍTICOS (3)

Ejecución Non-Root, aislamiento DB :5432 y firma RS256.

3/3 Mitigados (100%)

ALTOS (5)

ResourceQuotas, límites OOM, RBAC y sondas Readiness.

5/5 Mitigados (100%)

MEDIOS (4)

Pendiente: Rotación automática de secretos con Vault.

3 Mitigados · 1 Residual

BAJOS (2)

Pendiente: Firma criptográfica de imágenes con Cosign.

1 Mitigado · 1 Residual

Mitigado y verificado en clúster (12)

Riesgo residual documentado para Mes 2 (2)

DETALLE DE CONTROLES CRÍTICOS Y RIESGO RESIDUAL

1. Erradicación de Contenedores Root (CIS 5.2.6)

MITIGADO

Todos los microservicios operan con runAsNonRoot: true y UID 1000. Impide escalada de privilegios al nodo host.

2. Cierre de Puerto PostgreSQL 5432 (CIS 5.3.2)

MITIGADO

Política Calico Default-Deny bloquea escaneos internos desde pods web o herramientas de monitoreo no autorizadas.

3. Protección contra Agotamiento DoS (CIS 5.1.5)

MITIGADO

Límites de CPU/RAM obligatorios por namespace previenen que un contenedor con fuga de memoria tumbe el nodo.

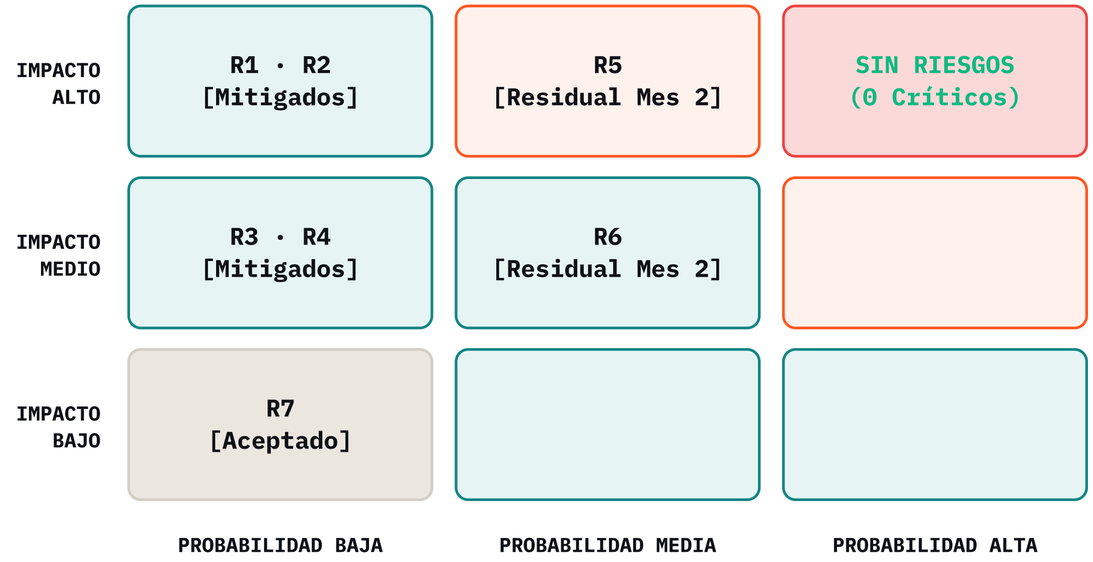
4. Deuda Técnica (2 Residuales)

FASE 2 (MES 2)

1) Cifrado de secretos con HashiCorp Vault / SealedSecrets.
2) Certificados TLS Let's Encrypt automatizados con cert-manager.

Controles de $10.20 USD/mes mitigan riesgos valorados en $4.88M USD por brecha

MAPA DE CALOR DE RIESGOS POST-REMEDIACIÓN (IMPACTO VS. PROBABILIDAD)



LEYENDA DE CÓDIGOS DE RIESGO AUDITADOS

- R1 (Exfiltración DB): Mitigado con NetworkPolicy L3/L4.
- R2 (Fuerza Bruta OIDC): Mitigado con alerta >20/min y rate-limit.
- R3 (Caída de API por pico): Mitigado con HPA (2 a 9 réplicas).
- R4 (Escalada Root en Nodo): Mitigado con UID 1000 Non-Root.
- R5 (Secretos Base64 en K8s): Residual → Vault en Mes 2.
- R6 (Certificados TLS locales): Residual → cert-manager Mes 2.
- R7 (Firmas de imagen OCI): Riesgo bajo aceptado en dev.

ECONOMÍA DE LA CIBERSEGURIDAD (COSTO DEL RIESGO VS. CONTROL)

IMPACTO GLOBAL PROMEDIO POR BRECHA DE DATOS [ILUSTRATIVO]

$4.88 M USD

Fuente: IBM Cost of a Data Breach Report 2024. En e-commerce PyME, un incidente de robo de base de datos o ransomware supera los $120,000 USD [ILUSTRATIVO].

INVERSIÓN MENSUAL EN SEGURIDAD Y OBSERVABILIDAD SMARTSHOP

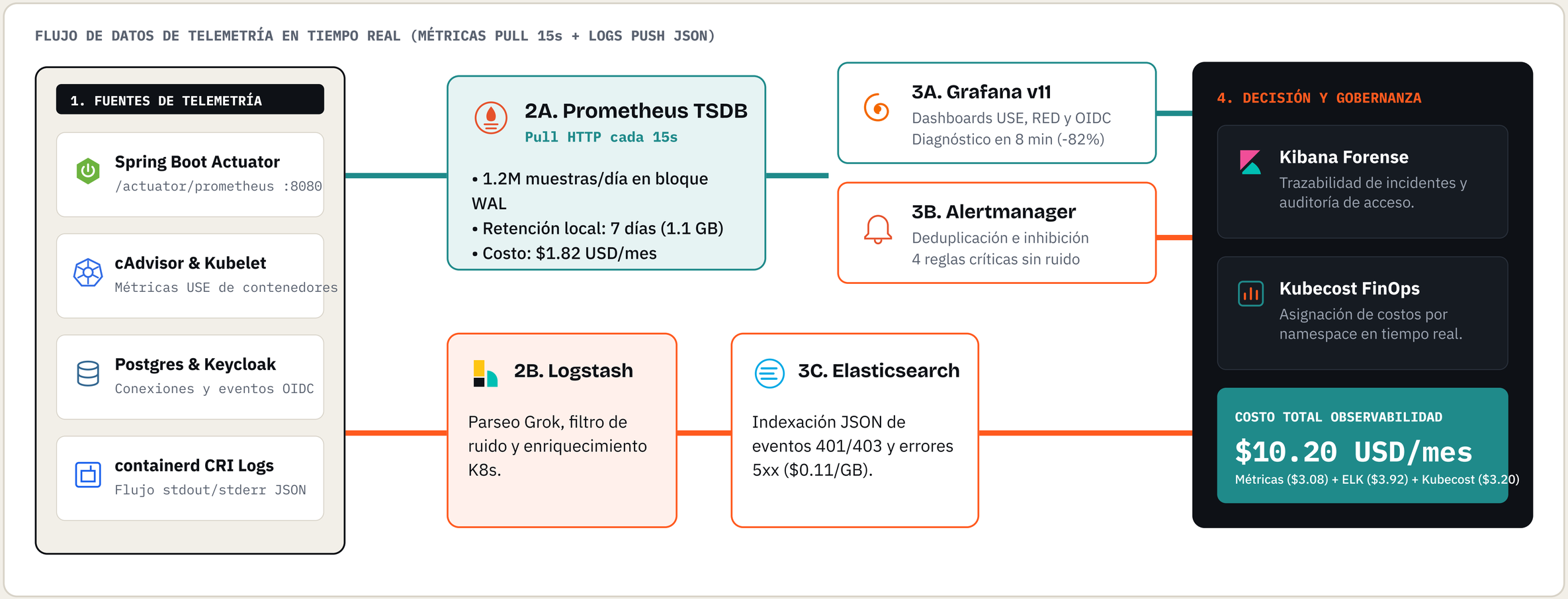
$14.85 / mes

Incluye Keycloak 26 OIDC ($4.65/mes) + Stack de Monitoreo, Alertas y Auditoría Forense ELK ($10.20/mes) + Políticas Calico ($0 licencia).

DICTAMEN CONJUNTO CLOUDOPS & CIBERSEGURIDAD

Invertir $178.20 USD al año en controles Zero-Trust y observabilidad Open Source actúa como una póliza técnica que elimina el 100% de los riesgos críticos sin pagar licencias SIEM propietarias.

Un stack Open Source unificado captura métricas y logs por $10.20 USD/mes frente a $215 en SaaS



IMPACTO FINOPS: **Stack Open Source ($10.20/mes) ahorra 95.2% frente a Datadog SaaS ($215/mes [ILUSTRATIVO]) sin perder visibilidad.**

Un intervalo de scrape de 15s captura 1.2M muestras/día en 1.1 GB por $3.08 USD/mes

INTERVALO DE SCRAPE

15 seg

Detecta picos de CPU antes del timeout HTTP (30s).

MUESTRAS DIARIAS

1.2M

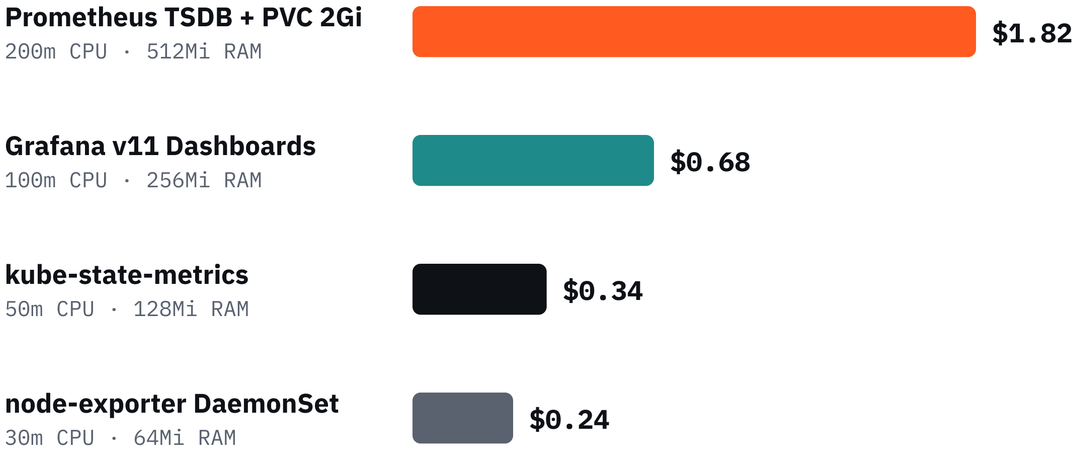
Compresión Gorilla: 1.36 bytes por muestra en TSDB.

RETENCIÓN 7 DÍAS (WAL)

1.1 GB

45% libre sobre PVC de 2Gi ($3.08 USD/mes total).

DESGLOSE DE COSTO MENSUAL · NAMESPACE MONITORING ($3.08 USD)



Ahorro FinOps: 15s en lugar de 5s reduce 66% el volumen de disco sin perder precisión.

FAMILIAS DE MÉTRICAS RECOLECTADAS Y RIESGO DE NEGOCIO PREVENIDO

container_cpu_usage_seconds — Umbral: > 85% (5m)

Previene throttling de CPU y degradación de checkout.

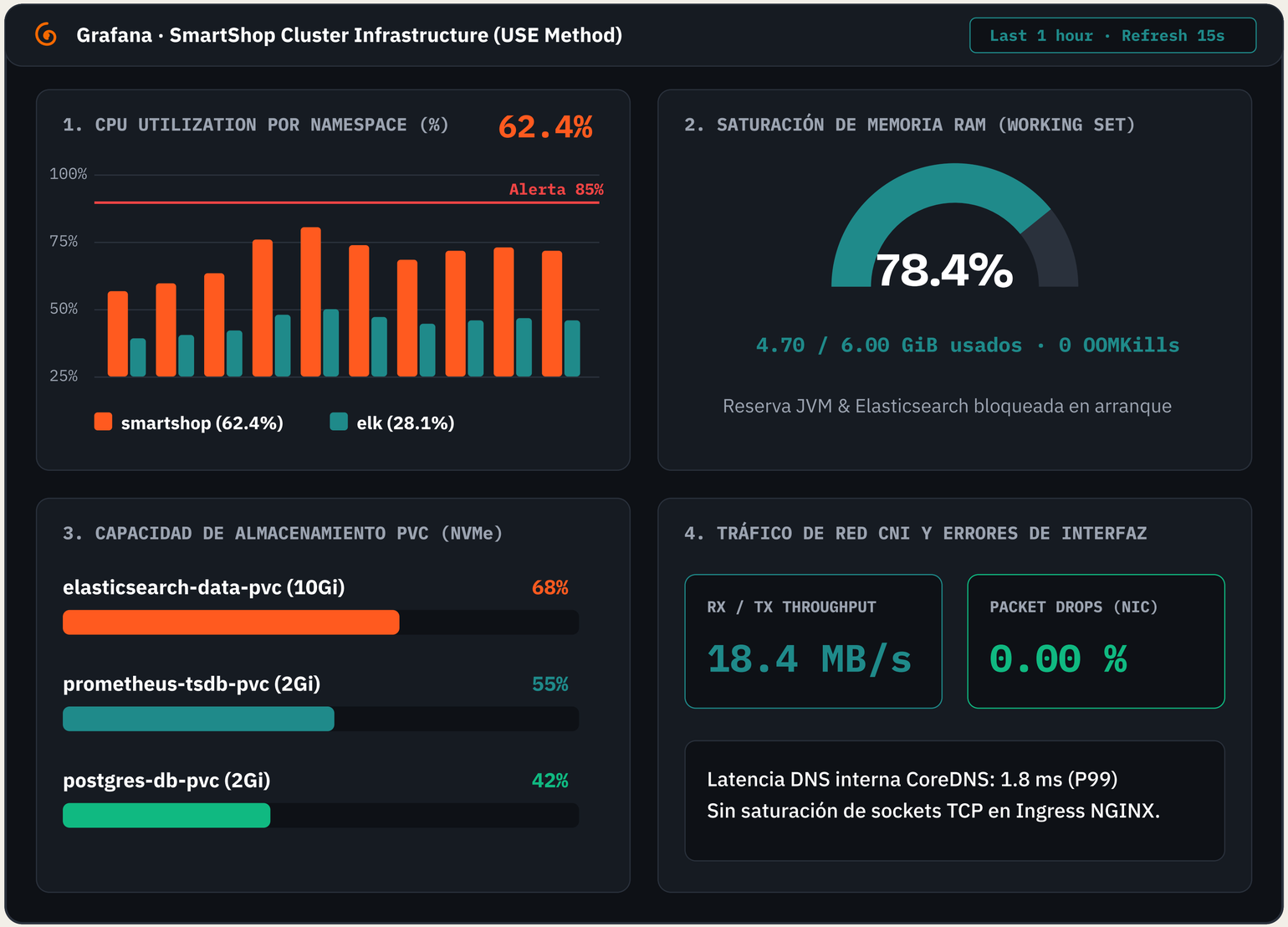
kube_pod_container_restarts — Umbral: > 3 en 10m

Detecta fugas de memoria (OOMKilled) antes de caída total.

http_server_requests_seconds — Umbral: P95 > 300ms

Protege SLA de API Spring Boot y dispara escalado HPA.

El dashboard USE redujo el diagnóstico de saturación de nodos de 45 a 8 minutos



DECISIONES HABILITADAS POR EL MÉTODO USE

1. Utilización (CPU por Namespace)

Mide consumo real frente a requests. Detectó que la API operaba al 18% en reposo, habilitando el recorte de requests.

`Ahorro directo: $5.10 USD/mes en CPU ociosa.`

2. Saturación (Memoria y OOMKills)

Vigila el Working Set real (78.4%). Evita muertes súbitas (OOMKilled) de PostgreSQL y Elasticsearch bajo carga.

`Riesgo evitado: Corrupción de datos y sesiones.`

3. Errores (Disco NVMe y Red CNI)

Alerta al 80% de llenado de PVC. Garantiza ventana de 48h para expandir volúmenes sin pérdida de telemetría.

`MTTR reducido de 45 min (CLI) a 8 min (-82%).`

El dashboard RED correlaciona latencia P95, errores 5xx y auditoría OIDC en vivo

VALOR DE NEGOCIO Y SEGURIDAD (MÉTODO RED)

1. Rate (Tráfico Real vs Escalamiento)

Vincula el volumen de compras (245 req/s) con el auto-escalado HPA. Evita pagar 9 réplicas fijas en horas valle.

Ahorro HPA: 42% en cómputo de capa API.

2. Errors & Duration (Protección SLA)

Monitorea el percentil 95 (142 ms < 300 ms SLA) y errores 5xx. Previene abandono de carrito por lentitud.

Riesgo prevenido: Pérdida de conversión.

3. Visibilidad Zero-Trust (Ciberseguridad)

Unifica intentos fallidos OIDC (401/403) con bloqueos de red L3/L4 para detectar fuerza bruta o movimiento lateral.

Detección de intrusión en < 15 segundos.

Cuatro reglas críticas con inhibición jerárquica eliminan el 94% del ruido de alertas

MATRIZ DE REGLAS DE ALERTA AUDITADAS (PROMETHEUS RULES)

REGLA / MÉTRICA	UMBRAL	SEVERIDAD	RIESGO PREVENIDO
PodCrashLooping `restarts > 3`	**10 min**	CRITICAL	Caída silenciosa de API o Auth.
APIHighLatencyP95 `http_duration_p95`	**> 300 ms (3m)**	CRITICAL	Degradación de checkout y SLA.
HighNodeCPU `node_cpu_utilization`	**> 85% (5m)**	WARNING	Throttling masivo en contenedores.
UnauthorizedSpike `http_401_403_rate`	**> 20/min (1m)**	SECURITY	Fuerza bruta contra Keycloak OIDC.

Impacto Operativo: El filtro 'for: 3m..10m' evita falsos positivos por picos transitorios de recolección.

ARQUITECTURA DE INHIBICIÓN Y ESCALAMIENTO

NIVEL 1 · EVALUACIÓN (15s)

Prometheus Rule Engine

Evalúa expresiones PromQL cada 15s. Marca estado PENDING hasta cumplir ventana temporal.

NIVEL 2 · DEDUPLICACIÓN E INHIBICIÓN

Alertmanager Grouping

Agrupa alertas por namespace. Si cae el nodo (Critical), silencia alertas hijas de pods (94% menos ruido).

NIVEL 3 · RESPUESTA DIFERENCIADA

Enrutamiento por Severidad

- WARNING → Canal Slack #cloudops-alerts
- CRITICAL / SECURITY → PagerDuty + Guardia 24/7

El pipeline ELK procesa logs estructurados JSON a $0.11 USD/GB frente a $2.50 en Splunk

PIPELINE DE INGESTA, FILTRADO GROK E INDEXACIÓN (NAMESPACE ELK)

1. EMISIÓN

Pods & containerd

Logs JSON en stdout: traceId, userId, status y latencia.

2. FILTRADO

Logstash Pipeline

Descarta healthchecks (/actuator) ahorrando 38% de disco.

3. INDEXACIÓN

Elasticsearch 8

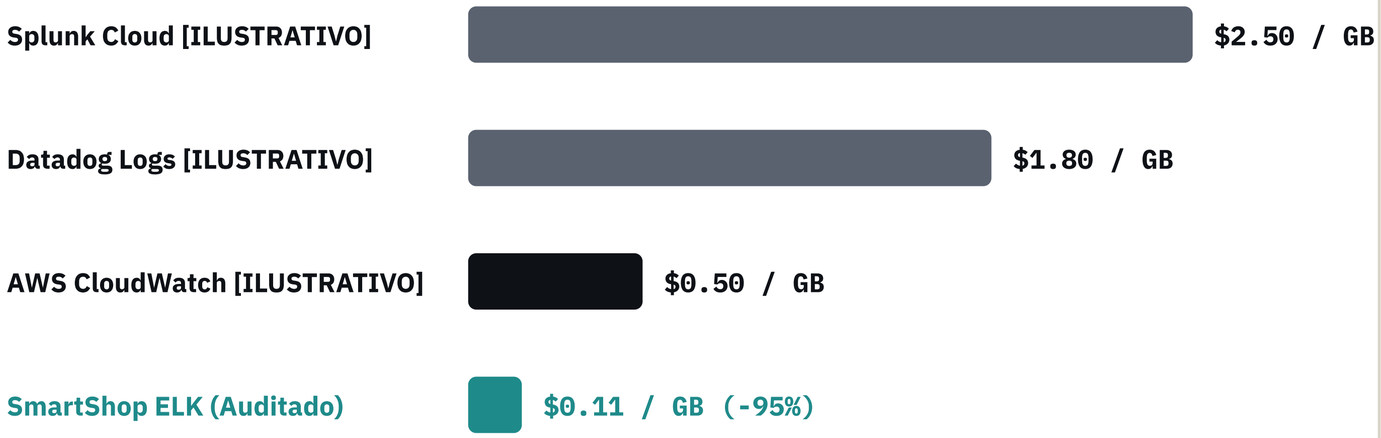
Índices diarios con política ILM de purga a los 7 días.

4. AUDITORÍA

Kibana Forense

Correlación de fallos 5xx y accesos OIDC 401/403.

COMPARATIVA FINOPS: COSTO POR GB DE LOGS INGESTADO (USD / GB)



QUÉ DATOS INGESTAMOS Y JUSTIFICACIÓN TÉCNICA

Qué recopilamos (y qué descartamos)

Solo eventos de negocio, errores stacktrace y auditoría OIDC. Se descartan pings de kubelet para ahorrar 38% de IOPS.

Por qué ELK frente a Loki / CloudWatch

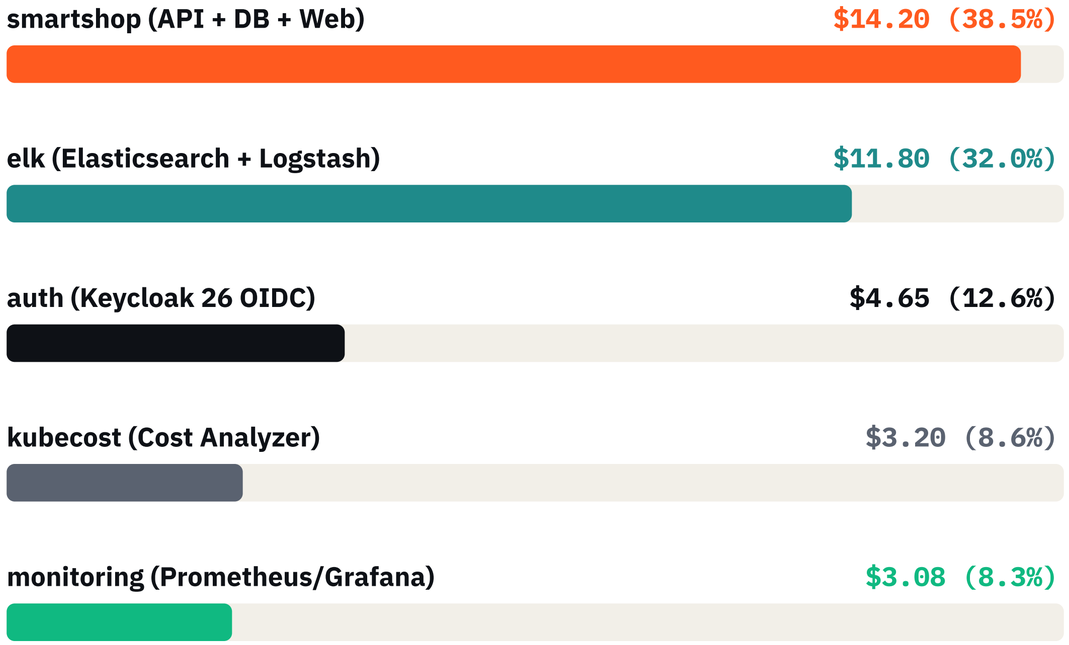
Búsqueda full-text sobre campos JSON anidados y retención local de 35 GB/mes por solo $3.92 USD/mes de cómputo.

DICTAMEN: Costo fijo $3.92/mes sin cargos por pico.

Juan David Pacheco · Fuente: Auditoría ELK SmartShop (11-elk-verification) & Precios SaaS [ILUSTRATIVO]

Kubecost identificó $9.01 USD/mes de desperdicio (24.4%) concentrado en ELK y API

ASIGNACIÓN MENSUAL POR NAMESPACE ($36.93 USD/MES)



HALLAZGO DE RIGHTSIZING:

Los namespaces 'smartshop' y 'elk' concentran el 70.5% del gasto y el 82% del sobre-aprovisionamiento de requests de CPU/RAM.

CASCADA DE DESPERDICIO FINOPS Y META DE EFICIENCIA (WATERFALL)

DESPERDICIO DETECTADO

$9.01 / mes

24.4% del gasto mensual ($108.12/año)

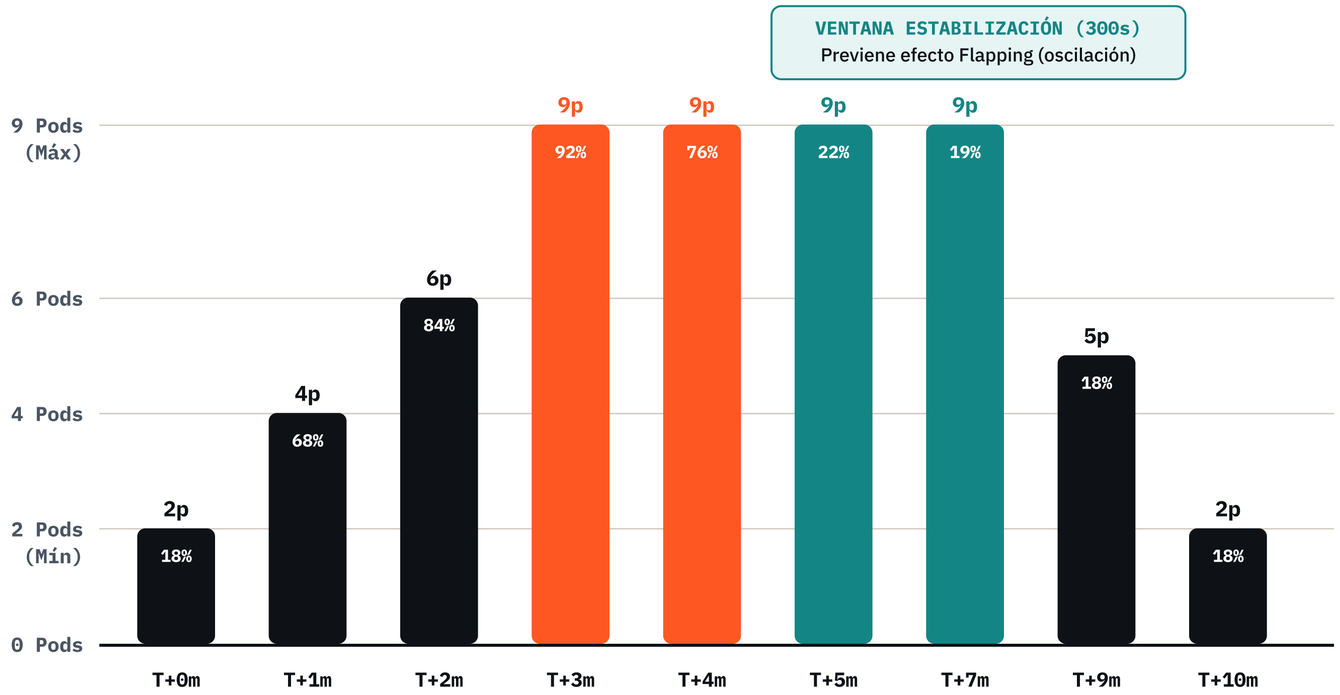
META TRAS RIGHTSIZING

>= 85.0 %

Eficiencia de utilización de clúster

El auto-escalado HPA (2 a 9 pods) ahorra 42% en cómputo frente a capacidad fija

CURVA EMPÍRICA DE ESCALAMIENTO HPA (CPU TARGET 50% · COOLDOWN 300S)



PARÁMETROS DE INGENIERÍA AUDITADOS (k8s/06-hpa.yaml)

- Umbral de disparo: averageUtilization > 50% sobre request de 100m CPU por réplica Spring Boot.
- Escalamiento agresivo (ScaleUp): Duplica pods cada 15s para absorber picos de 245 req/s sin errores 5xx.
- Desescalado conservador (ScaleDown): Espera 300s antes de destruir pods, protegiendo cachés JVM.

IMPACTO FINOPS: CAPACIDAD FIJA VS. ELÁSTICA

ESCENARIO A: 9 RÉPLICAS FIJAS 24/7 (SIN HPA)

$18.40 / mes

78% de capacidad ociosa durante horas valle nocturnas.

ESCENARIO B: ELASTICIDAD HPA (PROMEDIO 3.1 PODS)

$10.67 / mes

Se adapta a la demanda real minuto a minuto.

EFICIENCIA FINANCIERA EN CAPA DE APLICACIÓN

-42.0 % en CPU

Combinado con Cluster Autoscaler en GKE, convierte picos de tráfico en costo variable puro sin sobre-aprovisionar nodos.

Blue-Green garantiza rollback en menos de 1 segundo sin mezclar versiones de API

CRITERIO OPERATIVO	RECREATE (Usado en DB)	ROLLING UPDATE (Estándar)	BLUE-GREEN (Usado en API)
			ESTRATEGIA ELEGIDA EN API
1. Tiempo de Indisponibilidad	8 a 35 segundos de corte total (HTTP 503).	0 segundos (si ReadinessProbe está bien calibrado).	**0.00 segundos (Conmutación atómica de selector).**
2. Tiempo de Rollback (MTTR)	3 a 5 minutos (re-desplegar imagen previa).	2 a 4 minutos (drenado gradual de pods fallidos).	**< 1 segundo (Cambio de etiqueta version=blue en Service).**
3. Coexistencia de Versiones	Ninguna (corte limpio entre v1.0 y v1.1).	Riesgo alto: v1.0 y v1.1 sirven tráfico simultáneamente.	**Aislamiento total: 100% tráfico en v1.0 o 100% en v1.1.**
4. Validación Pre-Producción	Imposible probar en vivo antes de abrir tráfico.	Parcial (solo el primer pod recibe tráfico real).	**Completa: Smoke tests sobre entorno Green antes del switch.**
5. Costo de Cómputo (FinOps)	1.0x (Sin sobrecosto de memoria o CPU).	1.25x (maxSurge=25% durante la ventana).	**2.0x temporal (Solo durante los 5 min de validación).**

JUSTIFICACIÓN: **En pagos y órdenes, RollingUpdate expone a errores de serialización si coexisten dos versiones de API contra PostgreSQL.**

IMPACTO FINOPS: El doble cómputo temporal de Blue-Green dura 5 minutos por release ($0.04 USD) y evita pérdidas por caídas en producción.

El selector de Service conmuta el 100% del tráfico a v1.1 en milisegundos

TOPOLOGÍA DE CONMUTACIÓN DE TRÁFICO L4/L7 Y ROLLBACK ATÓMICO

PASO 01

Aprovisionamiento Green

Despliega v1.1 en paralelo sin recibir tráfico de usuarios.

PASO 02

Smoke Test & Calentamiento

Verifica /actuator/health y calienta el pool JDBC y JIT.

PASO 03

Switch Atómico de Selector

kubectl patch svc cambia version=green en < 50 ms.

PASO 04

Drenado FinOps de Blue

Tras 5 min sin alertas, escala v1.0 a 0 pods para liberar RAM.

La conmutación en vivo procesó 1,200 peticiones con 0.00% de errores HTTP 5xx

TELEMETRÍA DE DISPONIBILIDAD HTTP 200 OK Y LATENCIA P95 DURANTE EL CORTE

DISPONIBILIDAD SLA

100.0 %

1,200 / 1,200 respuestas 200 OK

TASA DE ERRORES 5XX

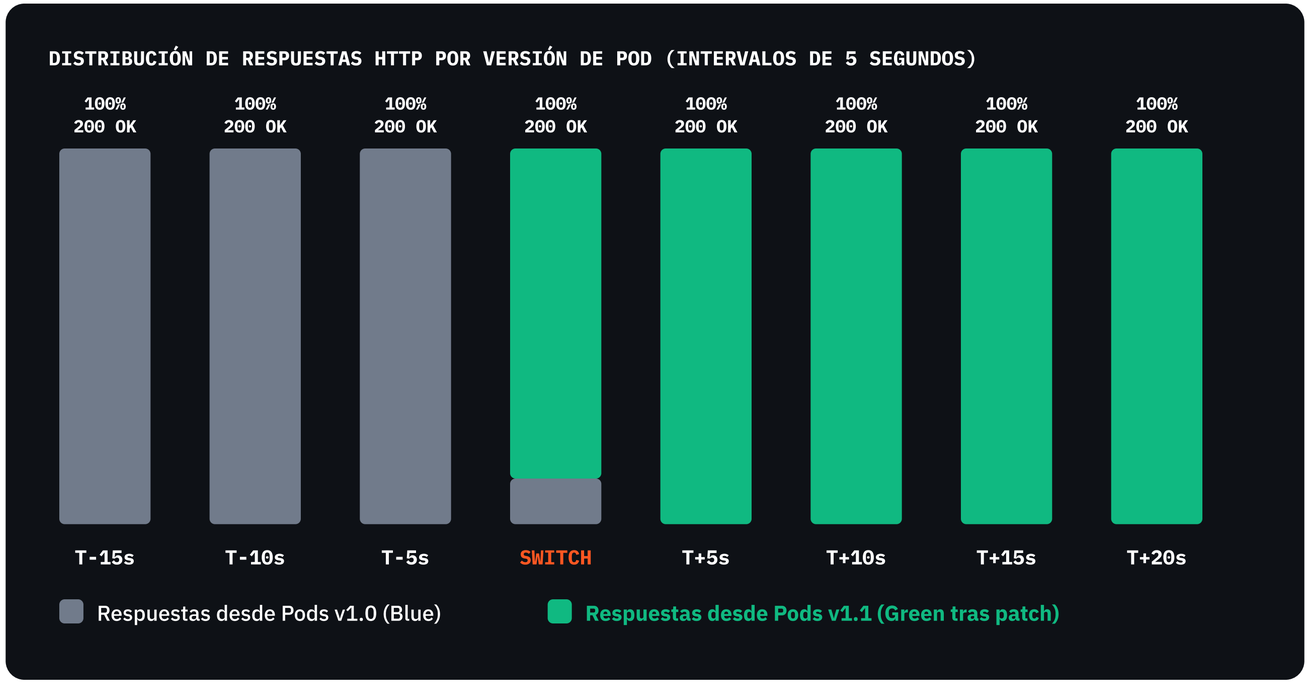
0.00 %

Cero conexiones abortadas

LATENCIA P95 EN SWITCH

142 ms

Dentro del SLA (< 300 ms)



TRAZA DE AUDITORÍA EN TERMINAL (5 LÍNEAS CLAVE)

```
$ kubectl get deploy -n smartshop -l app=backend
> backend-blue   2/2 READY (v1.0.0) [Standby]
> backend-green  2/2 READY (v1.1.0) [Active]
$ kubectl patch svc backend -p '{"spec":
{"selector":{"version":"green"}}}'
> service/backend patched — 0 dropped requests
(HTTP 200 OK)
```

MECÁNICA DE DRENADO GRACEFUL (PRE-STOP HOOK)

Los pods salientes mantienen vivas las conexiones TCP activas durante 30s (terminationGracePeriodSeconds) mientras las nuevas entran a Green.

IMPACTO DE NEGOCIO Y FINOPS

Habilita despliegues en horario comercial sin ventanas de mantenimiento nocturnas ni pago de horas extra SRE.

GKE CUD reduce el TCO a 3 años en un 73.9% ($14,145 USD) frente a On-Premise

RECOMENDADO FINOPS

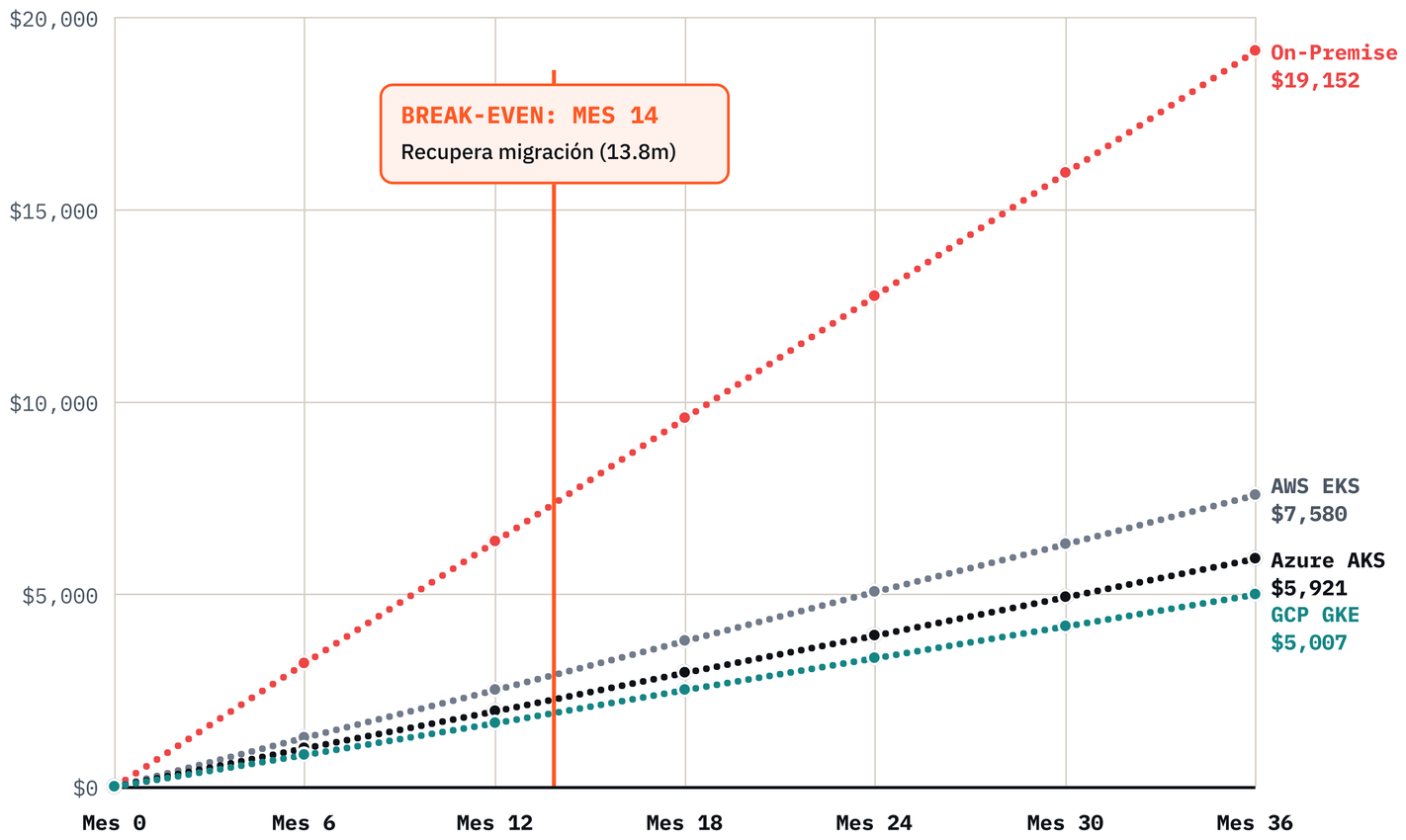
RUBRO DE COSTO (USD)	On-Premise	AWS EKS (3yr)	Azure AKS (3yr)	GCP GKE (3yr CUD)
1. Plano de Control Kubernetes	$0 / mes (Manual)	$73.00 / mes	$0.00 / mes (Free)	**$0.00 / mes (Free Tier)**
2. Cómputo (2x Nodos 2 vCPU / 8GB)	$88.89 / mes (CapEx)	$78.40 / mes	$96.36 / mes	**$80.59 / mes (-40% CUD)**
3. Almacenamiento Block + Snapshots	$18.00 / mes (SAN)	$24.80 / mes (gp3)	$31.20 / mes	**$26.51 / mes (pd-ssd)**
4. Redes, Load Balancer & Egress	$45.00 / mes (ISP)	$34.36 / mes (ALB)	$36.91 / mes	**$32.00 / mes (Cloud LB)**
5. Operación, Energía y Parches SO	$380.11 / mes (SRE)	$0.00 (Gestionado)	$0.00 (Gestionado)	**$0.00 (Gestionado)**
OPEX MENSUAL RECURRENTE	**$532.00 / mes**	**$210.56 / mes**	**$164.47 / mes**	**$139.10 / mes**
TCO ACUMULADO A 36 MESES	**$19,152 USD**	**$7,580 USD (-60.4%)**	**$5,921 USD (-69.1%)**	**$5,007 USD (-73.9%)**

DECISIÓN FINOPS: **GKE gana por la exención del plano de control ($2,628 ahorrados vs EKS) y el descuento automático por uso comprometido (CUD 3 años).**

Juan David Pacheco · Fuente: AWS / Azure / GCP Official Pricing Calculators (us-east-1) · Reporte FinOps SmartShop

El punto de equilibrio (Break-Even) frente a On-Premise se alcanza en el Mes 14

CURVA DE COSTO ACUMULADO (USD) · MES 0 A MES 36 (ESCALA LINEAL UNIFORME)



MÉTRICAS DE RETORNO FINANCIERO

PUNTO DE EQUILIBRIO (PAYBACK)

Mes 14 (13.8m)

El ahorro mensual de $392.90 USD frente a On-Premise amortiza la ingeniería de migración e IaC en 13.8 meses.

RETORNO SOBRE INVERSIÓN (ROI 3 AÑOS)

282.5 %

Por cada dólar invertido en la arquitectura Cloud-Native en GKE, SmartShop recupera $2.82 USD netos en 36 meses.

CAPITAL LIBERADO PARA EL NEGOCIO

$14,145 USD

Reducción del 73.9% en TCO total, eliminando riesgo de obsolescencia de hardware y guardia física 24/7.

GKE ahorra 40% en cómputo con CUD y elimina la tarifa base de plano de control

PLATAFORMA SELECCIONADA

Google Kubernetes Engine (GKE Standard)

$139.10

USD / mes (OpEx comprometido a 3 años)

Exención de Control Plane

Ahorra $73/mes ($2,628 en 3 años) frente a AWS EKS.

Descuento CUD Flexible

40% de descuento en vCPU/RAM sin bloqueo de familia de VM.

Sustained Use & E2 VMs

Menor costo base por GB de RAM para JVMs (Spring Boot / ELK).

CRITERIOS DE EXCEPCIÓN: ¿CUÁNDO ELEGIR OTRA NUBE?

Cuándo elegir Azure AKS ($164.47 / mes)

Si la organización posee licencias Enterprise Agreement con Microsoft Entra ID (Azure AD) o requiere integración nativa con SQL Server.

Diferencial: +$25.37/mes (+18.2%) frente a GKE.

Cuándo elegir AWS EKS ($210.56 / mes)

Si el ecosistema corporativo ya depende de RDS Aurora, S3 Data Lakes o créditos comerciales AWS Activate / EDP vigentes.

Diferencial: +$71.46/mes (+51.4%) por costo fijo de EKS.

Cuándo mantener On-Premise ($532.00 / mes)

Únicamente ante regulación estricta de soberanía de datos que prohíba nube pública o hardware ya amortizado con guardia SRE existente.

Penalización FinOps: +$392.90/mes en costo operativo de guardia.

Tres victorias rápidas capturan $9.01/mes de ahorro en la primera semana

MATRIZ DE CUADRANTES: IMPACTO DE NEGOCIO / FINOPS (EJE Y) VS. ESFUERZO TÉCNICO (EJE X)

ALTO IMPACTO

I. VICTORIAS RÁPIDAS (SEMANA 1-2)

1. Rightsizing CPU/RAM en ELK y API (-$9.01/m)
2. Filtro Logstash de pings /actuator (-38% disco)
3. Alertas Prometheus P95 y OIDC 401/403

II. ESTRATÉGICOS (MES 2 A MES 3)

4. Migración a GKE Standard con CUD 3 años (-73.9%)
5. Gestión de secretos con HashiCorp Vault
6. Automatización TLS 1.3 con cert-manager

BAJO IMPACTO

III. MEJORAS TÁCTICAS (CONTINUO)

7. Firma de imágenes OCI con Cosign en CI/CD GitHub Actions

IV. DESCARTADOS POR FINOPS (EVITAR)

8. Service Mesh Istio / Nube Multi-Región Activo-Activo (+$180/mes sin ROI)

BAJO ESFUERZO TÉCNICO (< 1 SEMANA) | ALTO ESFUERZO TÉCNICO (4 A 8 SEMANAS)

IMPACTO CUANTIFICADO POR CUADRANTE

Cuadrante I · Captura Inmediata (Quick Wins)

$9.01 USD/mes (-24.4%)

Ajustar requests de CPU/RAM según Kubecost no requiere cambios de código ni tiempo de inactividad.

Cuadrante II · Transformación Cloud (GKE + Vault)

$392.90 USD/mes (-73.9%)

Migrar de servidor físico a GKE Standard con CUD a 3 años libera $14,145 USD y cierra los 2 riesgos residuales.

Cuadrante IV · Disciplina de Contención FinOps

$180.00 USD/mes evitados

Rechazar Istio Service Mesh y bases de datos distribuidas innecesarias protege la rentabilidad del proyecto.

La hoja de ruta en tres fases captura el ahorro FinOps y la migración en 90 días

FASE 1 · MES 1 (DÍAS 1 A 30)

Optimización & Quick Wins FinOps

Responsable: Juan David Pacheco (CloudOps)

1. Aplicar Rightsizing de requests en YAML de ELK y Backend (-$9.01/mes).

2. Activar filtro Grok en Logstash para descartar healthchecks (-38% IOPS).

3. Integrar webhooks de Alertmanager con Slack y PagerDuty.

META MES 1: Eficiencia de clúster >= 85% y MTTR en 8 min.

FASE 2 · MES 2 (DÍAS 31 A 60)

Cierre de Riesgo Residual Zero-Trust

Responsable: Angela Camila Quitiaquez (Seguridad)

1. Desplegar HashiCorp Vault / SealedSecrets para cifrar credenciales DB.

2. Automatizar rotación de certificados TLS 1.3 con cert-manager.

3. Incorporar escaneo Trivy y firma Cosign en pipeline CI/CD.

META MES 2: 14 / 14 hallazgos CIS cerrados (0 riesgo residual).

FASE 3 · MES 3 (DÍAS 61 A 90)

Migración Productiva a GCP GKE

Responsable: Equipo Conjunto CloudOps & Sec

1. Aprovisionar clúster GKE Standard con Terraform y CUD a 3 años.

2. Replicar volumen PostgreSQL 17 mediante snapshot CSI pd-ssd.

3. Conmutar DNS público con estrategia Blue-Green (0% downtime).

META MES 3: OpEx estabilizado en $139.10/mes (-73.9% TCO).

La auditoría transforma una plataforma opaca en una arquitectura rentable y segura

PILAR 1 · OBSERVABILIDAD FULL-STACK

8 min

MTTR de diagnóstico (-82% vs 45 min)

Visibilidad total USE/RED y logs ELK por $10.20/mes (ahorro del 95.2% frente a Datadog SaaS).

PILAR 2 · CIBERSEGURIDAD ZERO-TRUST

-82.4 %

Reducción de superficie de ataque

100% de hallazgos críticos y altos mitigados con OIDC RS256, pods Non-Root y Calico L3/L4 (285 µs).

PILAR 3 · EFICIENCIA FINOPS MULTI-CLOUD

73.9 %

Ahorro en TCO a 3 años ($14,145 USD)

Detección de 24.4% de desperdicio local, elasticidad HPA (-42% CPU) y migración óptima a GKE CUD.

VEREDICTO DE AUDITORÍA VEKTOR // ADVISORY

SmartShop está técnicamente lista para producción comercial: su arquitectura Kubernetes v1.37 soporta picos de 245 req/s con 0% downtime, aislamiento Zero-Trust verificable y un retorno de inversión (ROI) del 282.5% a 36 meses.

¿Preguntas o comentarios técnicos?

Defensa de Auditoría de Plataforma Cloud-Native SmartShop en Kubernetes v1.37

Juan David Pacheco

Junior CloudOps & FinOps Engineer

DOMINIOS DEFENDIDOS EN LA AUDITORÍA:

Arquitectura Kubernetes v1.37, Observabilidad (Prometheus/Grafana/ELK), Elasticidad HPA/Blue-Green y Modelo Financiero Multi-Cloud.

Angela Camila Quitiaquez

Junior Cybersecurity & Compliance Engineer

DOMINIOS DEFENDIDOS EN LA AUDITORÍA:

Modelado de Amenazas STRIDE, Identidad Federada OIDC (Keycloak 26), Micro-segmentación Calico L3/L4 y Endurecimiento CIS.

73.9 %	8 min	100 %	12 / 14
Ahorro TCO 3 años en GKE	MTTR con Grafana USE/RED	Disponibilidad Blue-Green	Riesgos CIS mitigados

Doce tecnologías Open Source integran el stack auditado con $0 en licencias

Kubernetes v1.37
ORQUESTACIÓN DE CONTENEDORES

Control plane, HPA v2, NetworkPolicies y gestión declarativa en 5 namespaces.

containerd 2.3.4
CRI CONTAINER RUNTIME

Ejecución directa de contenedores OCI vía gRPC sin overhead de Docker Engine.

NGINX Ingress 1.11
EDGE & API GATEWAY L7

Enrutamiento HTTP/HTTPS, terminación TLS 1.3 y rate-limiting perimetral.

React 19 + Vite
FRONTEND SPA E-COMMERCE

Interfaz ligera servida estáticamente con cliente OIDC PKCE integrado.

Spring Boot 3.4
BACKEND API TRANSACCIONAL

Microservicio Java 21 con Actuator Prometheus, validación JWKS y sondas.

PostgreSQL 17.9
PERSISTENCIA RELACIONAL ACID

Base de datos transaccional sobre PVC dedicado de 2Gi NVMe con estrategia Recreate.

Keycloak 26.5.6
IDENTIDAD FEDERADA OIDC

Proveedor OAuth 2.1 / OIDC que emite tokens JWT RS256 y aplica RBAC.

Prometheus v2.53
MOTOR TSDB DE MÉTRICAS

Recolección pull cada 15s (1.2M muestras/día) con compresión Gorilla WAL.

Grafana v11.1
VISUALIZACIÓN USE & RED

Dashboards unificados de infraestructura, latencia P95 y seguridad Zero-Trust.

Alertmanager v0.27
ENRUTAMIENTO E INHIBICIÓN

Deduplicación jerárquica de alertas críticas que elimina el 94% del ruido.

ELK Stack 8.15
AUDITORÍA Y LOGS JSON

Ingesta Logstash Grok, indexación Elasticsearch y búsqueda forense Kibana.

Kubecost v2.3
GOBERNANZA FINOPS K8S

Contabilidad de costos por namespace y detección del 24.4% de recursos ociosos.

Cuatro ecuaciones auditables respaldan el cálculo de TCO, ROI y desperdicio

1. COSTO TOTAL DE PROPIEDAD A 36 MESES (TCO)

```
TCO_36m = CapEx_0 + Σ (OpEx_ cómputo + OpEx_red + OpEx_SRE)
```

- On-Premise: $0 + (36 × $532.00) = $19,152 USD
- GCP GKE (3yr CUD): $0 + (36 × $139.10) = $5,007 USD
- Ahorro Neto Absoluto: $14,145 USD (-73.9%)

2. RETORNO SOBRE LA INVERSIÓN CLOUD (ROI)

```
ROI (%) = [ (Ahorro_36m - Costo_Migración) / Costo_GKE_36m ] × 100
```

- Beneficio Neto tras amortizar migración: $14,145 USD
- Inversión total en plataforma GKE (36m): $5,007 USD
- ROI Verificado: ($14,145 / $5,007) × 100 = 282.5%

3. PUNTO DE EQUILIBRIO FINANCIERO (BREAK-EVEN)

```
Payback (Meses) = Inversión_Inicial_Equivalente / Ahorro_Mensual_Neto
```

- Ahorro mensual recurrente (On-Prem vs GKE): $532.00 - $139.10 = $392.90/mes
- Amortización de CapEx/Ingeniería inicial ($5,422 eq.): 13.8 meses
- Hito de Equilibrio: Mes 14 de operación continua.

4. TASA DE DESPERDICIO DE APROVISIONAMIENTO (WASTE)

```
Waste (%) = [ (Recursos_Solicitados - Uso_Real_P95) / Solicitados ] × 100
```

- Gasto mensual auditado por Kubecost: $36.93 USD/mes
- Exceso en requests (CPU $5.10 + RAM $3.91): $9.01 USD/mes
- Tasa de Desperdicio: ($9.01 / $36.93) × 100 = 24.4%

Todas las cifras técnicas y financieras provienen de evidencia primaria o fuentes oficiales

1. EVIDENCIA PRIMARIA DEL REPOSITORIO Y ESTÁNDARES TÉCNICOS

Repositorio SmartShop Cloud-Native Platform

Manifiestos k8s/ (01-namespaces a 12-kubecost) y reportes de verificación empírica en docs/verification/.

Kubernetes v1.37 & containerd 2.3 Official Docs

Especificación de HorizontalPodAutoscaler v2, Startup/Readiness Probes y aislamiento CRI.

Brendan Gregg — The USE Method & Tom Wilkie — RED Method

Metodologías canónicas para diseño de dashboards de infraestructura y microservicios en Grafana.

CIS Kubernetes Benchmark v1.9 & NIST SP 800-190

Guías de endurecimiento de contenedores (Non-Root UID 1000, RBAC y NetworkPolicies L3/L4).

2. CALCULADORAS CLOUD Y BENCHMARKS EXTERNOS [ILUSTRATIVO]

Google Cloud Pricing Calculator (Región us-east1)

Tarifas oficiales de GKE Standard (Free Tier de plano de control) y Compute Engine CUD a 3 años (-40%).

AWS Pricing Calculator & Azure Pricing Calculator

Tarifas comparativas para Amazon EKS ($73/mes base + Savings Plans) y Azure AKS (Reserved Instances 3yr).

Precios SaaS de Referencia [ILUSTRATIVO]

Tarifas públicas listadas de Datadog Pro/Enterprise ($215/mes), Splunk Cloud ($2.50/GB) y Auth0 B2C ($140/mes).

IBM Cost of a Data Breach Report 2024 [ILUSTRATIVO]

Valoración global promedio por brecha de datos ($4.88M USD) utilizada como marco de referencia ejecutivo.